



HIPAA Compliance Report
As of December 23,2024



www.riskpro.in



December 23, 2024

To,
The Management,
WizRocket Inc. (CleverTap)
India

HIPAA Compliance Report

Scope

Riskpro India was engaged to perform HIPAA Compliance audit for WizRocket Inc. (CleverTap) team which is likely to host EPHI for healthcare clients.

The regulatory scope of this report is limited to Health Insurance Portability and Accountability Act.

Summary Findings / Areas of Concern or Improvement:

- Under HIPAA privacy rules, CleverTap is considered a Business Associate.
- The organization has documented all necessary HIPAA specific policies and procedures.
- The organization has identified the extent of EPHI in CleverTap systems. It is listed in attached annexure 1. Adequate technical, administrative and physical safeguards are in place to ensure Confidentiality, Integrity and Availability for EPHI.
- The organization has required Information Security controls.
- Details of current safeguards are in the attached annexure 2.

Conclusion on HIPAA Compliance



Based on our review and based on the compliance checkpoints outlined in the attached review report, we believe that the organization and its data hosting is **"HIPAA Compliant"**.

A handwritten signature in black ink, appearing to read "Manoj Jain".

Manoj Jain, CPA
Founder and Director

Disclaimer: This report is intended only as an independent review of compliance against the HIPAA requirements and reporting of our findings to provide assurance to end clients about the HIPAA readiness of our client. This is not a certificate for HIPAA compliance or an audit opinion.

Annexure 1:

CleverTap is a Customer Lifecycle Management and Engagement platform that helps consumer brands to retain their users for life. Growth teams across industries use CleverTap's automation, AI/ML and personalization capabilities to manage and improve customer lifecycle by delivering the most consistent experience across all touchpoints. With a unique combination of a unified data platform, automated segmentation and insights, and omnichannel engagement, CleverTap enables brands to optimize and scale customer experiences in real time.

PII encryption feature for the CT (Clinical Trial) Platform complies with HIPAA, protecting the data from unauthorized access while ensuring encryption keys are securely managed. The encryption feature is implemented, and it meets the encryption requirements. Data is encrypted at the field or column level and cannot be decrypted by unauthorized users, including platform administrators. The keys used for encryption are securely managed and stored in AWS KMS, with access controls and logging configured to meet the standards. The platform's encryption mechanisms ensure that PII is inaccessible to unauthorized personnel, including those within the organization, and that data is protected at all stages.

CleverTap Architecture – CleverTap architecture consists of a Data Collection layer, fronted by AWS Elastic Load Balancers (ELBs), that accept data via HTTPS from client-side SDKs (as well as public REST API). Data Collection layer does only minimal validation before dropping data into a separate Data Processing layer for preparation and delivery to Data Store layer, where it is immediately available for querying. A separate Message Delivery Service (MDS) is responsible for querying the Data Store to generate and deliver messages via email, push notifications, and other channels. Some of this data could possibly be EPHI as defined under HIPAA.

Annexure 2: HIPAA Specific Safeguards:

Safeguards	Security Standards	Overall Compliance Rating	Remarks / Comments
Administrative Safeguard	Security Management Process §164.308(a)(1)	Compliant	- The organization is ISO 27001 Certified. The organization maintains comprehensive ISMS documentation. - The organization also maintains compliance with General Data Protection Regulation (GDPR) (EU) 2016/679, a regulation in European Union law on data protection and privacy for all individuals within the European Union. - Version control is implemented for all policies and procedures. Annual reviews are carried out for policies and procedures by the IS officer and approved by Information Security Group ISWG. - ISMS policies are kept on Confluence folder. - Various policies contain examples of unacceptable behaviour and other policy violations. HR has policies and procedures deal with violations with various degrees of severity. - Internal audit function has been setup, and the scope covers Information systems. - The Audit Committee consists of CISO, Information Security Officer, and the Information Security Working Group. - The organization recently successfully gone through SOC2 Type 2 certification from independent auditors. - Company has documented its compliance against HIPAA security rule in a HIPAA Manual. - CleverTap has risk management policy & procedure in place. - Information Security Team is involved in risk management process. - Various policies contain examples of unacceptable behaviour and other policy violations. HR has policies and procedures deal with violations with various degrees of severity. - Internal audit function has been setup, and the scope covers Information systems.
	Assigned Security Responsibility §164.308(a)(2)	Compliant	- Associate Director who holds the role of Data Protection Officer (DPO) with Senior Manager are responsible for security. - For HIPAA, assignments related to Security and Privacy officer responsibility are assigned.

Safeguards	Security Standards	Overall Compliance Rating	Remarks / Comments
			- The qualifications, experience and job description required for the role have been laid out in the roles and responsibilities document. - A formal Organisation chart is in place.
	Workforce Security §164.308(a)(3)(i)	Compliant	- The organization has procedures to give system The organization has procedures to enable access to employees only to those areas that have been decided upon by the process in which they have been assigned through BetterCloud tool. - ePHI are restricted for all employees. - Disciplinary policy explicitly states sanctions for violations of policy. - Security awareness program is conducted for every new user onboarded. All organization users are mandated to complete yearly refresher training that is conducted on our learning management system. - On exit / termination of a workforce member, the Infra team and Facilities team removes all logical and physical access. Inspected sample exit clearance records and exit tickets.
	Information Access Management §164.308(a)(4)(i)	Compliant	- The organization has procedures to give system The organization has procedures to enable access to employees only to those areas that have been decided upon by the process in which they have been assigned. through BetterCloud tool. - Defined JDs and lines of authority for reporting are in place. Responsibilities are defined in procedures manual. - Background verification checks as per process requirement are carried out prior to onboarding. - The organization has documented Physical access control policy and logical access control policy.
	Security Awareness and Training §164.308(a)(5)(i)	Compliant	- Information security trainings are provided to all new joiners as Induction and existing employee as refresher HIPAA Awareness training every year. - Upon completion of training all employees (participant) sign the confidentiality agreement certifying that he or she received the privacy training. - Trainings include Helpdesk Tool, Importance of Security, Data Classification, Malware & Protection, Physical / Logical Security & Data Usage, Surfing Web, Email Security, BYOD & Laptop Encryption, Removable Media: USB Drive, Incident Reporting. - The trainings are repeated annually. Effectiveness of the training is evaluated through a quiz. Results of the evaluations are maintained.

Safeguards	Security Standards	Overall Compliance Rating	Remarks / Comments
	Security Incident Procedures §164.308(a)(6)(i)	Compliant	- The organization has a well-defined incident management process. - The organization has implemented procedures to regularly review records of information system activity, such as audit logs, access reports, and security incident tracking reports. - Incident logs are retained sufficiently for forensics search in the event there is an incident. - Incident Management is currently handled through Jira as a third-party ticketing tool used for incident detection and recording. - The organization identifies and responds to suspected or known security incidents. Mitigate, to the extent practicable, harmful effects of security incidents that are known to the covered entity and document security incidents and their outcomes. Using Postmortem tool for Lesson learnt. - Tickets raised covers classification and initial support, Investigation and diagnosis, Resolution and recovery, Incident closure, Incident ownership, monitoring, tracking and communication.
			- The organization has documented backup policy and BC-DR plan and approved by the Management. There are no critical systems which includes ePHI. - Amazon Data Lifecycle Manager is used for regular backup operations. Daily backup report is configured, and corrective action is taken for any errors reported. Backup is monitored on daily basis by DevOps Team. - Business Continuity and Disaster Recovery procedures are in place. BCP test cases identified, and a test plan is in place. - BCP/DR plan with roles and responsibilities covers all systems is reviewed annually by IS officer and approved by ISWG team, - Disaster recovery teams & responsibilities are established. - The organization has established procedures that allow facility access in support of restoration of lost data under the disaster recovery plan and emergency mode operations plan in the event of an emergency. - Restoration of backups are implemented and tested by DevOps team annually.
	Evaluation §164.308(a)(8)	Compliant	The organization conducts Threat Intelligence through Orca tool internally and external VAPT through Third Party Scanning production infrastructure and AWS hardening for known vulnerability in the entire environment.

Safeguards	Security Standards	Overall Compliance Rating	Remarks / Comments
			- Remediation is done as per policy for vulnerability management. - Laptops are updated through Kandji MDM Device Management Tool.
	Business Associate Contracts and Other Arrangements §164.308(b)(1)	Not Applicable	- The organization is not a covered entity and is a business associate. - The organization has signed BAA with its key service provider. - Organization has put forth comprehensive safeguards to protect CIA of client data including Policies and Procedures, Technical safeguards, administrative safeguards, Physical safeguards, Documentation, Contracts etc.
Physical Safeguards			Inspected BCP /DR policy and business impact analysis document.
	Facility Access Controls §164.310(a)(1)	Compliant	- The Organization has documented Physical and environmental security policy. - Cloud is responsible for providing physical and environmental controls, equipment maintenance, facility security, access control procedures as well as redundancy for its services where CleverTap production systems is hosted. - Appropriate physical security controls such as security guards, CCTV monitoring, proximity card-based access control system, appropriate protection for sensitive equipment, Server room access register, Visitors badge, Visitor register, Provision of UPS, emergency entrance/exits, fire protection equipment is in place. CCTV recordings are retained for a period of thirty days.
	Workstation Use §164.310(b) Workstation Security §164.310(c)	Compliant	- Access control, password management, remote working policies, acceptable use policy, clear desk and clear screen policy is in place. - The organization has documented acceptable use policy. asset management policy, clear desk and clear screen policy. access control, password management, remote working policy in place. - The Organization do not process, store or have access to PHI/ePHI. There is no access to PHI from client environment. - CleverTap team is trained in not downloading any ePHI (even if client provides access during support) on local desktops / laptops.
	Device and Media Controls §164.310(d)(1)	Compliant	The organization has Media Handling, Data Backup, Asset Management Policy and Technology Equipment Handling and Disposal Policy

Safeguards	Security Standards	Overall Compliance Rating	Remarks / Comments
			- An IT Asset Inventory is maintained. - Data Retention Policy is available. Retention policy is dependent on business requirements and contracts with the clients.
Technical Safeguards	Access Control §164.312(a)(1)	Compliant	- Data access is according to the role assigned to the user as defined in the Role Management. AWS IAM for users assigned to role. - Access to RedHat SSO is based on request raised by HR team. HR Team is part of admin user list to RedHat SSO. - Administrator or privileged access is limited to the Systems team and no other support group, or any other team has privileged access. - Workforce members have no access to the electronic Protected Health Information (ePHI). - Only whitelisted applications are allowed to run on the corporate laptops. - Exit /separated employees access revoke done within one business day of the last working by Corp IT Team. - The policy for locked screens is applicable to all workstations and laptops.
	Audit Controls §164.312(b)	Compliant	- The user identity is mapped to processes on which the user is assigned. Before any change is carried out, appropriate authorizations are taken. - Splunk tool collects application logs, CloudTrail logs and sent alerts. - Log monitoring tools are configured to log activities using admin access carried out on servers, database, application, network. Logs in critical devices / software are configured to log errors and problems.
	Integrity §164.312(c)(1)	Compliant	- The organization has access control policy in place. - The organization has safeguards to ensure that no data can be accessed or edited in an unauthorized manner.
	Person or Entity Authentication §164.312(d)	Compliant	- The organization has procedure for user registration and authentication mechanism. Production infra log-in is through single sign-on (SSO). - Appropriate authorizations are taken for any changes. - Kandji tool carry list of admin. - The organization passwords are stored with strong encryption using tool.

Safeguards	Security Standards	Overall Compliance Rating	Remarks / Comments
	Transmission Security §164.312(e)(1)	Compliant	- EBS volumes storing end user data are encrypted with AES 256-bit encryption with keys managed by AWS KMS. - All data transmitted through the API is encrypted using secure protocols and TLS with algorithms and key management practices. - Connection to production system/AWS is encrypted and RedHat SSO auth is enabled. - Client supplied data is filtered and validated before processing. - The organization cryptography policy on place ensures industry standard encryption algorithm for data at rest and in-transit
Organizational Requirements	Business Associate Contracts and Other Arrangements §164.314(a)(1)	Compliant	- The organization has signed BAA with cloud service provider hosting production infra and other third parties. Inspected a sample BAA template for client. - When appointed as a business associate, adequate safeguards are taken in physical, technical and administrative areas.
	Requirements for Group Health Plans §164.314(b)(1)	Not Applicable	Not applicable
Policies, Procedures, and Documentation Requirements	Policies and Procedures § 164.316(a) Documentation §164.316(b)(1)	Compliant	- The organization is ISO 27001:2013 certified and maintains elaborate ISMS documentation. It is annually reviewed and is version controlled. - Data Protection Policy. Data Privacy Policy, Data Retention Policy (DRP) is in place. The data retention policy is based on business requirements and client contractual requirements. - Procedure for control of documents includes document retention requirement and how the documentation is made available to those persons responsible for implementation - References of applicable HIPAA standards are included in the policies and procedures.